Compiled Testing Plan Compliance Report

Azucena's Dental Clinic Management System — Capstone Project

1. Level 1 — Master Unit Testing Registry

Series 100: User Authentication, Security & Session Management

Focuses on crypto hashes, formatting rules, token lifetimes, and gatekeeping rules.

ID	Item	Verdict	Evidence
UT-101	validateEmailFormat(email)	**IMPLEMENTED**	filter_var($email, FILTER_VALIDATE_EMAIL) used in register_api.php and login_api.php; rejects malformed addresses.
UT-102	validatePasswordStrength(pwd)	**IMPLEMENTED**	security_password_policy_errors() in config/security.php requires 8+ characters plus upper/lower/digit/special; enforced at registration and password reset.
UT-103	hashUserPassword(plainText)	**IMPLEMENTED**	security_hash_password() calls password_hash() with PASSWORD_BCRYPT (config/security.php); never stores plaintext.
UT-104	verifyPasswordMatch(plain, hash)	**IMPLEMENTED**	password_verify() used in login_api.php, with a hash_equals() legacy-plaintext migration path (never a loose == comparison).
UT-105	generateSessionToken(userId)	**IMPLEMENTED**	Uses native PHP sessions (security_start_session() + session_regenerate_id(true) on every login) for RBAC state, instead of a JWT. This is an intentional architecture choice, not a gap — session_regenerate_id() defends against session fixation the same way a freshly-issued token would.
UT-106	isTokenExpired(timestamp)	**IMPLEMENTED**	Role-based idle timeouts in config/session_check.php (patient 15m, staff 1h, secretary 2h, doctor none) auto-destroy the session and redirect to login once exceeded.
UT-107	sanitizeHtmlInput(userInput)	**IMPLEMENTED**	Fixed 8/11/2026: added security_sanitize_html_input() to config/security.php (strips <script>/<style> blocks, strip_tags, then htmlspecialchars).

			Wired into the shared patient-profiling filter (config/patient_profiling_helpers.php) so Medical History, Medications, Allergies, and Background Notes are stripped of markup before insert; also applied directly in save_clinical_record.php (per-tooth comments, visit profiling) and the public Contact Us form. This is a second, independent layer on top of the output-side escaping (htmlspecialchars/escapeHtml) already used everywhere this data is rendered.

2. Level 2 — Master Integration Testing Registry

Series 100: Frontend Interface ↔ Backend API Integration

Validates the data-sharing bridge between user input screens and server-side processing controllers.

ID	Item	Verdict	Evidence
IT-101	UI Registration Form ↔ Auth Controller	**IMPLEMENTED**	Frontend serializes the form to JSON, POSTs to register_api.php, handles the JSON success response, and redirects to login.
IT-102	Login Screen ↔ State/Session Manager	**IMPLEMENTED**	login_api.php establishes a server-side session (not a client-stored token); $_SESSION['role'] drives Admin/Secretary/Doctor/Patient access on every subsequent request via check_session().
IT-103	Interactive Odontogram UI ↔ Chart Controller	**IMPLEMENTED**	odontogram/main.js captures tooth clicks, maps them to FDI tooth numbers (adult/pediatric charts), and updates chart colors via save_clinical_record.php without a full page reload.
IT-104	Booking Calendar UI ↔ Schedule Controller	**IMPLEMENTED**	assets/api/appointments/get_available_dates.php, get_timeslots.php, and smart_schedule.php compute procedure duration, check for conflicts, and return only open time blocks to the calendar UI.

3. Level 3 — Master System Testing Registry

Series 100: User Authentication, Security & Account Management

ID	Item	Verdict	Evidence
ST-101	Account Registration	**IMPLEMENTED**	register_api.php checks for an existing email/phone before insert and blocks submission with "Email already exists".
ST-102	Login Security	**IMPLEMENTED**	Invalid credentials return a generic "Invalid email or password" (auth_fail() in login_api.php) — does not reveal whether the email or password was wrong. 5 failed attempts locks the account for 15 minutes, beyond what the plan requires.
ST-103	Password Masking	**IMPLEMENTED**	type="password" used consistently across login, registration, reset, and change-password forms (includes/password_field.php).
ST-104	Form Validation	**IMPLEMENTED**	Server-side required-field checks return specific messages (e.g. "All required fields must be filled"); forms also carry HTML5 required attributes for inline validation.
ST-105	Role-Based Access	**IMPLEMENTED**	check_session($allowed_roles) in config/session_check.php destroys the session and redirects to login when the logged-in role is not permitted on that portal.
ST-106	Session Logout	**IMPLEMENTED**	Cache-Control: no-store/no-cache headers sent on every session-driven page load; session_destroy() on logout prevents the back button from restoring the dashboard.

Series 200: Core Data Management & Transaction Processing (CRUD)

ID	Item	Verdict	Evidence
ST-201	Record Creation	**IMPLEMENTED**	Consistent success-toast + redirect-to-list-view pattern across add_patient.php, add_user.php, create_booking.php.
ST-202	Input Data	**IMPLEMENTED**	Numeric fields (price, fee, duration, stock-style

	Boundaries		quantities) use type="number" with min/step constraints on services, billing, and inventory-style forms; server-side casts reject non-numeric values.
ST-203	Record Modification	**IMPLEMENTED**	update_patient.php, update_user.php, update_appointment.php persist edits via UPDATE queries, confirmed to survive a page refresh.
ST-204	Record Removal	**IMPLEMENTED**	assets/js/app-confirm.js drives a "Are you sure you want to delete this record?" modal (37 call sites via the data-confirm attribute) before any destructive delete action.
ST-205	Table Pagination	**IMPLEMENTED**	DataTable pagination controls (assets/js/main.js) keep prior pages' rows in memory while paging through large record sets.

Series 300: Search, Filtering & Information Retrieval

ID	Item	Verdict	Evidence
ST-301	Global Text Search	**IMPLEMENTED**	Debounced live search (patientLiveSearch) calls assets/api/patients/search_patients.php and filters the grid instantly — confirmed wired end-to-end, not a dead endpoint.
ST-302	Empty Search State	**IMPLEMENTED**	"No patients match your search." message renders in place of the table when a query returns zero rows (admin/admin_modules/manage_patients.php) .
ST-303	Multi-Filter Sorting	**IMPLEMENTED**	Status filter tabs combine with the free-text search box on the same table (e.g. secretary New Patients / arrivals views) to narrow results by more than one criterion at once.

Series 400: Reporting, Document Exports & Analytic Computations

ID	Item	Verdict	Evidence

ST-401	Mathematical Audit	**IMPLEMENTED**	config/billing_helpers.php centralizes subtotal, discount (senior/PWD/custom), and installment math with consistent rounding — verified against manual calculation.
ST-402	PDF Document Export	**IMPLEMENTED**	Fixed: assets/api/billing/export_invoice_pdf.php now renders through Dompdf (composer.json requires dompdf/dompdf) and streams a real application/pdf file, replacing the earlier window.print()-only placeholder.
ST-403	Spreadsheet Export	**IMPLEMENTED**	assets/api/reports/export_bir.php generates a comma-separated (CSV) export of sales/collections with date-range filtering.

Series 500: System Configurations & Notifications

ID	Item	Verdict	Evidence
ST-501	UI Feedback Alerts	**IMPLEMENTED**	A global loading overlay (app-page-loading) plus disabled/loading button states block duplicate submissions on payment and upload actions.
ST-502	Settings Profiling	**IMPLEMENTED**	admin/admin_modules/settings.php persists configuration changes via update_profile_api.php; changes reflect immediately across relevant modules.

4. Level 4 — Comprehensive User Acceptance Testing (UAT) Survey

Not code-verifiable. Per the testing plan, this level requires:

• Part 1: Participant Profile Matrix — 3 to 5 domain experts/clients and 10 to 15 end-users, each with a signature/initials and testing date.

• Part 2: Full ISO/IEC 25010-aligned survey (Functional Suitability, Usability, Performance Efficiency, Security, Reliability, Maintainability & Portability) with Likert ratings from each participant.

• Part 3: Formal Client Acceptance & Sign-off — a signed acceptance statement from the client, dated 2026.

These are organizational/paperwork deliverables, not system behaviors, and must be completed with actual clinic staff and patients as participants — they are intentionally excluded from the code-verification scope of this report.

5. Changes Made In This Update

The following fixes were applied to the codebase as part of reconciling against the official testing plan:

• UT-107 (XSS input sanitization): added security_sanitize_html_input() and security_sanitize_html_input_array() to config/security.php. Wired into the shared profiling filter (config/patient_profiling_helpers.php) covering save_profiling.php, create_walkin.php, and create_secretary_record.php; applied directly inside save_clinical_record.php (profiling fields and per-tooth comments) and the public Contact Us form (submit_contact_message.php). Free-text fields such as Medical History are now stripped of <script>/HTML markup at write time, in addition to the existing output-side escaping (htmlspecialchars/escapeHtml) used when this data is displayed or exported to PDF.

• IT-103 (Odontogram integration, previously mislabeled as "live search" in the internal draft): re-verified against the official plan's actual IT-103 definition (tooth click → chart update) and confirmed implemented. The earlier draft's separate "live search" finding (an unused search_patients.php endpoint) was a different item not present in the official plan's IT series; it has since been wired up under ST-301 in this report and confirmed working.

• ST-402 (PDF export): confirmed dompdf/dompdf is installed and export_invoice_pdf.php now streams a real PDF, closing the gap noted in the previous report.

6. Scope Note

Level 4 of the source Testing Plan (Comprehensive User Acceptance Testing Survey, ISO/IEC 25010-aligned) requires live participant sign-off, printed signatures, and organizational testing dates — it cannot be verified from source code and is intentionally excluded from the pass/fail table above. It should be conducted separately with actual clinic staff and patients as end users, and the signed results filed alongside this report.